Government of Canada Gouvernement du Canada

DAOD 6003-2, Information Technology Security Risk Management

Table of Contents

1. Introduction
2. Definitions
3. Overview
4. Risk Management
5. Consequences
6. Responsibilities
7. References

---

1. Introduction

Date of Issue: 2014-01-14

Application: This DAOD is a directive that applies to employees of the Department of National Defence (DND employees) and an order that applies to officers and non-commissioned members of the Canadian Armed Forces (CAF members).

Approval Authority: Assistant Deputy Minister (Information Management) (ADM(IM)) / Chief Information Officer (CIO)

Enquiries: Director Information Management Security (DIM Secur)

Top of Page

2. Definitions

authorization (*autorisation*)

The ongoing process of obtaining and maintaining official management decision by a senior organizational official to authorize operation of an information system and to explicitly accept the risk of relying on the information system to support a set of business activities based on the implementation of an agreed-upon set of security controls, and the results of continuous security assessment. (*IT Security Risk Management: A Lifecycle Approach (ITSG-33)*, Communications Security Establishment Canada)

information technology operational personnel (*personnel opérationnel des technologies de l'information*)

Persons who work as network or system administrators or managers, account managers or help desk personnel, or provide other information technology support. (Defence Terminology Bank record number 47901)

information technology security control (*contrôle de sécurité des technologies de l'information*)

A management, operational, or technical high-level security requirement prescribed for an information system to protect the confidentiality, integrity, and availability of its IT assets. Security controls are implemented using various types of security solutions that include security products, security policies, security practices, and security procedures. (*IT Security Risk Management: A Lifecycle Approach (ITSG-33)*, Communications Security Establishment Canada)

information technology security control profile (*profil de contrôle de sécurité des technologies de l'information*)

A set of security controls that are the minimum requirements for an information technology security function or information system.

Note – A profile must satisfy business needs and Treasury Board baseline security controls with due consideration for the technical context and the threat. (Defence Terminology Bank record number 47575)

information technology security practitioner (*praticien de la sécurité des technologies de l'information*)

A person who performs an engineering, implementation, maintenance or other information technology security function to protect the confidentiality, integrity and availability of information technology systems and assets. (Defence Terminology Bank record number 47902)

operational authority (*autorité opérationnelle*)

The person who has the authority to define requirements and operating principles, set standards and accept risk within their area of responsibility. (Defence Terminology Bank record number 43435)

risk management (*gestion du risque*)

A systematic approach to setting the best course of action under uncertainty by identifying, assessing, understanding, making decisions on and communicating risk issues. (*Framework for the Management of Risk*, Treasury Board)

security authority (*autorité de sécurité*)

The person who has the authority to identify risk, provide advice and security standards for endorsement by the operational authority and technical authority, and monitor compliance within their area of responsibility. (Defence Terminology Bank record number 43436)

security risk management (*gestion du risque de sécurité*)

A component of an overall risk management process involving the organization and coordination of activities and processes for controlling security risk. (*Operational Security Standard: Management of Information Technology Security (MITS)*, Treasury Board)

technical authority (*autorité technique*)

The person who has the authority to set technical specifications and standards, manage configurations, provide technical advice and monitor compliance within their area of responsibility. (Defence Terminology Bank record number 43437)

Top of Page

3. Overview

Context

3.1 The Treasury Board *Framework for the Management of Risk* establishes that departments and agencies must ensure the integration of risk management into the activities of their organizations.

3.2 The Treasury Board *Operational Security Standard: Management of Information Technology Security (MITS)* provides that departments must continuously manage the security risks to information and information technology (IT) assets throughout the life cycle of their programmes and services.

3.3 IT security risks result from the exposure of IT systems and IT assets to the compromise of their confidentiality, integrity, availability, intended use and asset value by accidental or deliberate threats and natural hazards. IT security risk management is the process used to manage these risks.

3.4 IT security risk management is one of several components of the IT Security Programme and the Departmental Security Program that the DND and the CAF need to perform as a routine part of their ongoing business and operations. IT security risk management is a key process in the delivery of secure and reliable IT services that support the mission and mandate of the DND and the CAF.

3.5 This DAOD is part of the *DND and CF IM and IT Policy Framework* and should be read in conjunction with other relevant ADM(IM) policies, instructions, directives, standards and guidance.

Objectives

3.6 The objectives of this DAOD are to:

a. establish IT security risk management for programmes, systems and services;
b. establish IT security risk management as an important business enabler within the decision-making process; and
c. identify responsibilities for:
    i. the identification, management, documentation and monitoring of IT security risks; and
    ii. providing direction and guidance on IT security risk management practices.

Expected Results

3.7 The expected results of this DAOD are:

a. increased efficiency and transparency of IT security risk management processes;
b. improved security risk management of IT systems and IT assets throughout the entire life cycle of the systems and assets;
c. increased awareness and accountability for IT security risk decisions; and
d. improved consistency in IT security risk management.

4. Risk Management

General

4.1 IT security risk management is a multifaceted undertaking that requires the involvement of DND employees and CAF members to establish DND and CAF objectives, define IT security requirements, develop IT security controls and operate secure IT systems that support DND business and CAF operations.

4.2 The DND and CAF IT security risk management processes and activities have replaced the certification and accreditation (C&A) process with the assessment and authorization (A&A) process for IT-enabled projects and IT systems.

4.3 The DND and CAF IT security risk management processes and activities:

a. align with the processes and activities described in the *Information Technology Security Risk Management: A Lifecycle Approach (ITSG-33)* of the Communications Security Establishment Canada, as well as integrate into all IT-enabled projects, IT systems and IT assets throughout the development life cycle; and
b. ensure that key steps are performed on a continual basis throughout the life cycle of IT systems and IT assets, and ensure IT security risk management is applied from a DND and CAF perspective.

4.4 IT security risk management enables the:

a. IT security authority (SA) to identify the IT security risks associated with IT assets; and
b. operational authority (OA) to make decisions on risk issues within their delegated area of responsibility.

4.5 Within the DND and the CAF, IT security risk management is conducted by DIM Secur, as the DND and the CAF IT SA, with the support of the applicable IT system technical authority (TA) to:

a. assess IT system security requirements;
b. select and implement IT system security control profiles;
c. monitor and assess IT security controls; and
d. identify any required IT security control updates.

Definition of IT Security Risk Management

Requirements

4.6 Managers at all levels must define their IT security risk management requirements to ensure that their IT systems and IT assets are appropriately protected from compromise.

Selection and Deployment of IT Security Control Profiles

4.7 The SA selects the appropriate IT security control profile that meets the requirements of the target IT system or IT asset. The OA, project manager or programme and service delivery manager must then consult DIM Secur to adjust specific IT security controls to meet the IT security requirements of the IT system or IT asset. The OA, project manager or programme and service delivery manager must subsequently implement the customized IT security control profile onto their IT system or IT asset.

Monitoring and Assessment of IT Security Controls

4.8 The SA, IT security practitioners and IT operational personnel must continually monitor and assess the performance of the implemented IT security controls in IT systems and IT assets, through the collection, consolidation and continual analysis of IT security control performance metrics. Monitoring IT security controls ensures that the selected IT security controls remain relevant and appropriate for the constantly changing threat environment.

4.9 The SA, IT security practitioners and IT operational personnel must ensure that the OA, project manager or programme and service delivery manager, as applicable, is informed of any changes in the previously accepted risk level.

Identification of IT Security Control Updates

4.10 Based on the IT security control performance analysis, the OA may need to update the implemented IT security controls. The OA, in consultation with the SA and TA, may direct that the IT security controls be re-evaluated and adjusted until an acceptable level of residual risk is reached. The OA subsequently accepts the residual risk and the updated IT security controls are then implemented. Changes in any of the following could initiate an IT security control update:

a. business or mission objectives;
b. information sensitivity;
c. IT security requirements;
d. threat assessments or threat agents; and
e. IT system or IT asset performance.

Theatre of Operations IT Security Risks

4.11 The nature of threats in a theatre of operations can differ greatly from the somewhat static perspective of a system-specific view. Although commanders have discretion in managing operational and tactical risks, the acceptance of significant IT security risks on the basis of operational efficiency must be weighed against the impacts to the confidentiality, integrity and availability of the information on IT systems. When a decision is made to accept a particular risk that affects the security of an IT system, the commander must report the factors leading to the acceptance of that risk to DIM Secur.

4.12 B-GJ-005-502/FP-000, *Risk Management for CF Operations*, provides instruction on the decision-making process to assist commanders and their staffs in identifying, analyzing, evaluating and controlling all types of risk.

Top of Page

5. Consequences

Consequences of Non-Compliance

5.1 Non-compliance with this DAOD may have consequences for both the DND and the CAF as institutions, and for DND employees and CAF members as individuals. Suspected non-compliance will be investigated. The nature and severity of the consequences resulting from actual non-compliance will be commensurate with the circumstances of the non-compliance.

Note – In respect of the compliance of DND employees, see the Treasury Board *Framework for the Management of Compliance* for additional information.

Top of Page

6. Responsibilities

Responsibility Table

6.1 The following table identifies the responsibilities associated with this DAOD:

The …	is or are responsible for …
ADM(IM)	• approving and issuing the IT security control profiles for DND and CAF IT systems.

DIM Secur (as the SA)	• providing and managing an IT security risk registry for the storage of information acquired from IT security risk management activities and risk decisions; • developing instructions, standards and guidelines for IT security risk management that align with Government of Canada best practices; • developing and recommending for approval IT security control profiles for DND and CAF IT systems; • providing advice on IT security controls and their implementation; • providing the IT security control profiles and threat assessment reports to personnel who are responsible for deploying and operating IT systems and IT assets; • monitoring to ensure that IT security risks and risk decisions are tracked in the IT security risk registry; • reviewing the IT security threat and vulnerability reports; • identifying the risks associated with IT systems and IT assets; • performing risk assessments and developing safeguard recommendations with a scope that reflects the sensitivity, criticality and complexity of the IT assets being assessed; • providing risk assessments and safeguard recommendations that support informed, practical and cost-effective risk management decision making;

- monitoring continually for changes in the threat environment and recommending the necessary adjustments to maintain the authority of IT systems and IT assets to operate;
- monitoring and assessing the performance of the implemented IT security controls;
- notifying applicable OAs, TAs and IT security practitioners of changes to threats or vulnerabilities that could impact risks to their IT systems and IT assets;
- monitoring for compliance with this DAOD and other relevant policies and instructions; and
- notifying the ADM(IM) of any non-compliance with this DAOD.

OAs	• determining the highest level of risk that a business function or mission can tolerate; • ensuring that risks to their programmes, systems and services are managed appropriately; • consulting with business continuity plan, privacy, information management and other functional specialists to ensure that risks within these areas of responsibility are identified and managed; • monitoring their information and IT assets for changes in value; • ensuring that risk assessments for their IT assets are re-evaluated in light of changes to asset value, threats and vulnerabilities; • approving adjustments to the implemented IT security controls to maintain the authority of IT systems to operate; and • reporting their IT security risk decisions to DIM Secur for subsequent entry in the IT security risk registry.
TAs	• ensuring that IT systems are implemented and operated in accordance with the approved IT security controls; • developing and deploying, as required, IT security controls for the IT systems used by the DND and the CAF; • installing, testing, patching and monitoring technical safeguards to IT assets within their area of responsibility; and • ensuring that the technical safeguards are operating effectively.

Commander, Canadian Forces Information Operations Group	• monitoring and researching IT security threats and vulnerabilities that apply to DND and CAF IT systems and IT assets; and • notifying the SA of any change in IT security threats or vulnerabilities.
IT security practitioners	• continually monitoring and assessing the performance of the implemented IT security controls in IT systems and IT assets; • notifying the SA of any required changes or updates to IT security controls; • identifying the risks associated with IT systems and IT assets within their area of responsibility; • performing risk assessments and developing safeguard recommendations within their area of responsibility, with a scope that reflects the sensitivity, criticality and complexity of the IT assets being assessed; • providing risk assessments and safeguard recommendations within their area of responsibility that support informed, practical and cost-effective risk management decisions; • continually monitoring for changes in the threat environment and recommending the necessary adjustments to maintain the authority of IT systems to operate; • monitoring and assessing the performance of the implemented IT security controls; and • notifying the SA and applicable OA and TA of any changes to threats or vulnerabilities that could impact risks to their IT assets.

IT operational personnel	• monitoring and assessing the performance of the implemented IT security controls in IT systems and IT assets within their area of responsibility; and • notifying the SA and applicable OA and project manager or programme and service delivery manager of any changes to the accepted risk level.
programme and service delivery managers	• defining their IT security risk management requirements; • consulting with DIM Secur to ensure that the appropriate IT security control profile has been chosen for the IT system operation; and • implementing the appropriate and approved IT security control profile for the applicable IT system.
DND employees and CAF members	• complying with all Government of Canada, DND and CAF policies, instructions, directives and standards in respect of IT security risk management.

Top of Page

7. References

Acts, Regulations, Central Agency Policies and Policy DAOD

- *Criminal Code*

- *Financial Administration Act*
- *National Defence Act*
- *Privacy Act*
- *Framework for the Management of Compliance*, Treasury Board
- *Framework for the Management of Risk*, Treasury Board
- *Policy on Information Management*, Treasury Board
- *Policy on Management of Information Technology*, Treasury Board
- *Policy on Privacy Protection*, Treasury Board
- *Directive on Departmental Security Management*, Treasury Board
- *Directive on Recordkeeping*, Treasury Board
- *Operational Security Standard: Management of Information Technology Security (MITS)*, Treasury Board
- DAOD 6003-0, *Information Technology Security*

Other References

- DAOD 1002-0, *Personal Information*
- DAOD 1003-1, *Business Continuity Planning Program*
- DAOD 6001-1, *Recordkeeping*
- DAOD 6002-1, *Management of Information Technology*
- DAOD 6002-8, *Electronic Authentication and Authorization*
- DAOD 6002-9, *Information Technology Asset Management*
- DAOD 6002-10, *Management of Information Technology Projects*
- DAOD 6003-1, *Information Technology Security Programme*
- *National Defence Security Policy*
- *National Defence Security Instructions*
- *DND and CF IM and IT Policy Framework*
- *IT Security Risk Management: A Lifecycle Approach (ITSG-33)*, Communications Security Establishment Canada
- B-GJ-005-502/FP-000, *Risk Management for Canadian Forces Operations*

Date modified: 2024-12-16